Mizan Security Strategy v2.1 — Prioritized Requirements Checklist

Status: Working checklist for a proposed strategy; this is not proof of implementation, certification, or deployment readiness.
As-of evidence reviewed: repository security documentation and the 11 Nov 2026 Mizan production UI audit.
Named owners: Not assigned; role placeholders below must be replaced by accountable people.
Control status rule: Only cite evidence directly observed in code/tests/reports. A repository design/test claim is not equivalent to live production enforcement. A UI label is not proof of backend enforcement.

Status legend

- **Documented; not deployment-verified** — a repository document or test describes the control, but current target-deployment operation is not established.
- **Partial / gap remains** — some related mechanism/evidence exists, but the full requirement is not evidenced.
- **Not evidenced** — no sufficient implementation or test evidence was found in the reviewed sources.
- **Blocked in audited tenant** — production prerequisites or records were absent in the 11 Nov 2026 audit; this does not prove all deployments are identically configured.

Proposed release gates

- **G0 — Architecture & ownership:** approved data flows, boundaries, threat model, named owners, failure behavior, and key/deployment decisions.
- **G1 — Secure core / sensitive-data pilot:** identity, tenancy, data protection, logging, key, upload, and fail-closed controls evidenced in the target environment.
- **G2 — External processing / RAG:** G1 passed; explicit transfer allowlist, signed Gate 1 records, retrieval isolation, AI-security and failure tests passed.
- **G3 — Model release / customer runtime:** signed provenance, anti-rollback, support-access, runtime and Golden Test controls passed.
- **G4 — Enterprise assurance:** recovery, incident exercises, independent assessment, vulnerability disclosure, and compliance evidence accepted.

Gates are proposed. Product and Security owners must approve their scope and dependencies before treating them as release criteria.

Priority	ID	Requirement	Owner placeholder	Evidence-led status (not a blanket implementation claim)	
P0	MZN-01	Asset, data-flow, and trust-boundary inventory	Security Lead (TBD) + Platform/DevSecOps (TBD)	**Documented; current deployment inventory not reconciled.** `M15_ASSET_AND_TRUST_BOUNDARY_INVENTORY.md` lists AST-01..12 and TB boundaries.	De da pr ov re
P0	MZN-02	MFA, SSO, and privileged identity controls	Product Owner (TBD) + Identity/Platform Lead (TBD)	**Partial / not evidenced.** Repo status documents password hashing, sessions, CSRF, and RBAC; reviewed evidence does not establish deployed MFA/SSO or privileged-account MFA.	En re pr gl te
P0	MZN-03	Tenant isolation across databases, storage, vectors, queues, caches, and artifacts	Application Engineering Lead (TBD)	**Documented in repo; production cross-tenant test not run in this audit.** `M15_TENANT_ISOLATION_AUDIT.md` cites test_sec_002, _009, _014, _016, _019, _037, _038.	Au te or co lo

Priority	ID	Requirement	Owner placeholder	Evidence-led status (not a blanket implementation claim)	
P0	MZN-04	Key hierarchy, BYOK/HYOK, rotation, revocation, and recovery	Security Lead (TBD) + Key Custodian (TBD)	**Partial.** `M15_CRYPTOGRAPHIC_TRUST_AND_KEY_MANAGEMENT.md` documents Ed25519 purposes, local key storage, and fail-closed verification; HSM/offline threshold custody and BYOK/HYOK support are not evidenced.	Ke ro rej dc ke
P0	MZN-05	Default-deny external transfer policy	Security Lead (TBD) + Data Plane Lead (TBD)	**Partial; audited tenant is blocked at Gate 1.** Repo status/docs describe raw-data export blocking and Gate 1 guards. On 11 Nov 2026 production audit, the synthetic dataset was READY but Approvals showed 0 masking runs / 0 signed attestations.	Se eg ur sig pr
P0	MZN-06	Classification, scanning, and masking	Data Protection Lead (TBD) + Application Engineering (TBD)	**Partial; live masking path not demonstrated.** Repo status describes Presidio/UAE recognizers and Gate 1 signing. Audit validated synthetic upload/parse/preview/freeze only; no masking run or signature appeared in audited tenant.	Sy pc ma m ve re
P0	MZN-07	Isolated, disposable, network-restricted document/evaluation/training jobs	Platform/DevSecOps Lead (TBD) + AI Engineering Lead (TBD)	**Not evidenced sufficiently.** Project strategy/status descriptions are not isolation proof; reviewed docs do not establish the actual sandbox boundary and network policy.	Sa te m cl su
P0	MZN-09	Protected, separate-domain audit logs and sealed evidence	Security Operations Lead (TBD) + Platform/DevSecOps (TBD)	**Partial.** Repo docs cite audit events and telemetry sanitization; separate-admin write-once storage and two-person sealed-evidence release/expiry were not evidenced.	At ap ap au qu
P0	MZN-13	Fail-behavior matrix implemented and tested	Platform/DevSecOps Lead (TBD) + Security Lead (TBD)	**Not evidenced as a complete matrix.** The attached strategy defines proposed behavior; no full dependency-fault test report was found.	Au op sir clo cu
P0	MZN-21	Vulnerability management and patch SLA	Security Lead (TBD) + DevSecOps Lead (TBD)	**Partial.** `M15_SECURITY_FINDINGS_REGISTER.md` documents six resolved findings; `PROJECT_STATUS.md` reports clean scanners. A complete asset-specific patch SLA and live remediation clock evidence were not verified.	Ac sc de pr sy SB
P1	MZN-08	Agent identity, tool allowlists, scoped permissions	Runtime Lead (TBD) + AI Engineering Lead (TBD)	**Partial.** `M15_RUNTIME_AND_SITE_AGENT_SECURITY.md` cites single-use enrollment, per-site agent identity, typed command allowlist, and replay test. Per-agent AI identity/data scope/tool budgets are not evidenced end-to-end.	Ur cr te re te
P1	MZN-12	Incident notifications, acknowledgement, and escalation	Security Operations Lead (TBD) + Platform/DevSecOps (TBD)	**Partial.** `M15_TELEMETRY_AND_NOTIFICATION_SECURITY.md` documents telemetry and webhook validation; real primary/backup delivery and timed escalation evidence was not found.	Sy se de fai nc
P1	MZN-18	AI output, injection, SSRF, and retrieval authorization defenses	AI Security Lead (TBD) + Application	**Partial.** `M15_THREAT_MODEL.md` documents webhook SSRF and tenant-aware RAG risks; complete prompt-	Ac te va

Priority	ID	Requirement	Owner placeholder	Evidence-led status (not a blanket implementation claim)	
			Engineering Lead (TBD)	injection/unsafe-output/agent-tool tests were not evidenced by reviewed materials.	re te re
P1	MZN-20	Metadata-first logs and sealed evidence	Security Operations Lead (TBD) + Privacy/Legal (TBD)	**Partial.** `M15_TELEMETRY_AND_NOTIFICATION_SECURITY.md` cites token/PII sanitization tests. Separate evidence-key escrow, two-person release, and fixed deletion schedule are not evidenced.	Inj ve ev ac de
P1	MZN-14	Signed packages, provenance, and SBOM	Release Engineering Lead (TBD) + Security Lead (TBD)	**Partial.** `M15_MODEL_SUPPLY_CHAIN_SECURITY.md` describes SHA-256 manifest/signature checks and unsafe-format rejection. SBOM generation/verification and reproducible-build evidence were not found in reviewed artifacts.	CI pr ta de ve
P1	MZN-19	Immutable offline backups and restore drills	Platform/DevSecOps Lead (TBD) + Key Custodian (TBD)	**Partial.** `M15_BACKUP_AND_DISASTER_RECOVERY.md` records a local rehearsal (RTO 0.023s, RPO 0s) with digest verification. Independent immutable/offline destination and production restore evidence are not established.	De de st RT cl
P1	MZN-22	Independent penetration testing	Security Lead (TBD) + Independent Assessor (TBD)	**Not evidenced as independent.** Repo status reports internal penetration rehearsal 20/20; no independent assessor report was found.	Si in Co re re
P1	MZN-25	Incident response plan and tabletop	Incident Commander (TBD) + Security Operations (TBD)	**Partial.** `M15_VULNERABILITY_RESPONSE_AND_INCIDENT_HANDLING.md` provides a written runbook. A named responder roster, tested notification chain, and tabletop evidence were not found.	Ta re nc pr co
P2	MZN-10	Sentinel Detect/Decide/Act separation	Sentinel Product/Engineering Lead (TBD) + Security Lead (TBD)	**Not evidenced; proposed architecture only.** The strategy describes the split; reviewed repository docs do not prove these separate components and privileges exist.	Co IA co sir ex
P2	MZN-11	Signed, scoped, expiring containment orders	Sentinel Engineering Lead (TBD) + Key Custodian (TBD)	**Not evidenced for containment orders.** Repo docs describe signed Gate/site-agent commands, not this three-part Sentinel order protocol.	Re wr ex or hu ac
P2	MZN-15	Anti-rollback signed minimum-version floor	Release Engineering Lead (TBD) + Runtime Lead (TBD)	**Partial.** Supply-chain docs describe revocation checks and safe rollback targets; a signed minimum-version floor distribution/enforcement was not evidenced.	Be flo ou re
P2	MZN-16	Customer-approved just-in-time support access broker	Support Operations Lead (TBD) + Identity/Platform Lead (TBD)	**Not evidenced.** No broker flow or session recording/expiry test was found in reviewed evidence.	De ap cu Re br
P2	MZN-17	Severity model, regulatory clocks, and escalation	Incident Commander (TBD) + Privacy/Legal	**Partial / conflicting documents.** `M15_VULNERABILITY_RESPONSE_AND_INCIDENT_HANDLING.md`	Ap sir

Priority	ID	Requirement	Owner placeholder	Evidence-led status (not a blanket implementation claim)	
			(TBD)	lists severities and response targets; strategy calls acknowledgement targets placeholders. Reconcile contractual/regulatory triggers and confirm targets are deliverable.	tir es re
P2	MZN-23	Vulnerability disclosure policy	Security Lead (TBD) + Legal/Communications (TBD)	**Not evidenced.** Strategy proposes named intake and triage; no public/private disclosure policy or monitored intake channel was found.	Pu an ha di ro
P2	MZN-24	Framework mapping and compliance evidence	Compliance Owner (TBD) + Security Lead (TBD)	**Partial.** Repo contains ASVS mapping/checklists; target framework (SOC 2/ISO 27001), control owner, evidence collection, scope, and independent readiness not selected/verified.	Ap cr re in

Immediate recommended sequencing

1. **G0:** appoint role owners; reconcile asset/data-flow inventory; decide deployment/data boundaries, identity, keys, and failure semantics.
2. **G1:** close MZN-02 through MZN-07, MZN-09, MZN-13, and MZN-21 for the specific pilot environment; exercise negative tests and document exact evidence. The audited production tenant currently had no Gate 1 signed attestation, so it is not evidence of an approved-data flow.
3. **G2:** prove transfer/classification failure behavior, retrieval isolation, AI tool and injection defenses; only then enable external processing/RAG for approved synthetic or authorized test data.
4. **G3:** establish package/SBOM provenance, anti-rollback, support broker, runtime validation, Golden Tests, and containment guardrails before model/site activation.
5. **G4:** complete immutable/offline restore proof, incident tabletop, independent penetration test, vulnerability disclosure, and framework gap assessment before enterprise security claims.

Evidence maintenance rules

- Keep source artifact path, commit/build identifier, environment, test command, run date, result, reviewer, and exclusions for every “verified” status.
- Reconcile contradictory documents before publication. In particular, strategy acknowledgement targets are placeholders while an incident runbook lists numerical response targets.
- Recheck production state separately from repository tests. Current audit evidence: production API health/readiness succeeded; Gate 1 approvals showed 0 masking runs, 0 pending reviews, 0 signed attestations; runtime test reported no active ready slot. A synthetic dataset v1 was frozen READY but was not approved.
- Do not mark a requirement “implemented” or “passed” solely because it appears in a proposed strategy, status report, architecture diagram, UI, or checklist.